

Лабораторная работа №3

Кибербезопасность предприятия

Абакумова Олеся Герра Гарсия Максимиано Антонио Канева Екатерина Клюкин
Михаил Ланцова Яна

23 октября 2025

Российский университет дружбы народов, Москва, Россия

Информация

Студенты группы НФИбд-02-22:

- Абакумова Олеся
- Герра Гарсия Максимиано Антонио
- Канева Екатерина
- Ключин Михаил
- Ланцова Яна

Цель работы

Защитить научно-техническую информацию предприятия от внутреннего нарушителя.

Выполнение лабораторной работы

Уязвимость 1. Слабый пароль пользователя.

The screenshot shows a web application interface for incident management. The main window is titled 'Добавление инцидента' (Add Incident). The form contains the following fields:

- Название** (Title): Слабый пароль пользователя (Weak user password)
- Дата и время события** (Event date and time): 19.10.2025 12:10
- Источник** (Source): 10.10.2.10 (MS Active Directory)
- Пораженные активы** (Affected assets): 10.10.2.10 (MS Active Directory)
- Описание** (Description): со словарем. После успешной авторизации на файловом сервере нарушитель загружает .bat файл и получает доступ к учетным данным пользователя dev1.
- Рекомендации** (Recommendations): Для закрытия уязвимости необходимо изменить пароль на более сложный, не содержащийся в словаре. Для изменения пароля на сервере AD открыть «Active Directory Users and
- Индикаторы компрометации** (Compromise indicators): Слабый пароль
- Прикрепить файл** (Attach file): A section with a circular arrow icon and the text 'Перетяните файл в эту область или Выберите файл' (Drag file to this area or Choose file).

On the right side of the form, there is a 'Добавить инцидент' (Add incident) button and a 'Панель' (Panel) / 'Таблица' (Table) toggle.

Рис. 1: Добавление инцидента по уязвимости 1

Уязвимость 1. Слабый пароль пользователя.

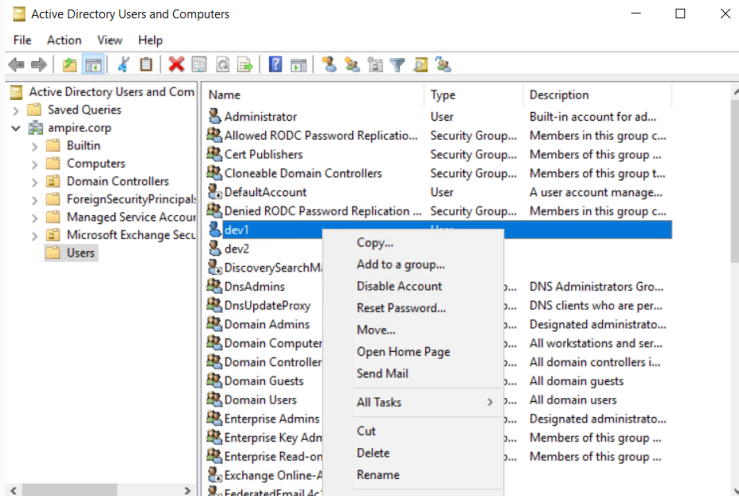


Рис. 2: Пользователь со слабым паролем

Уязвимость 1. Слабый пароль пользователя.

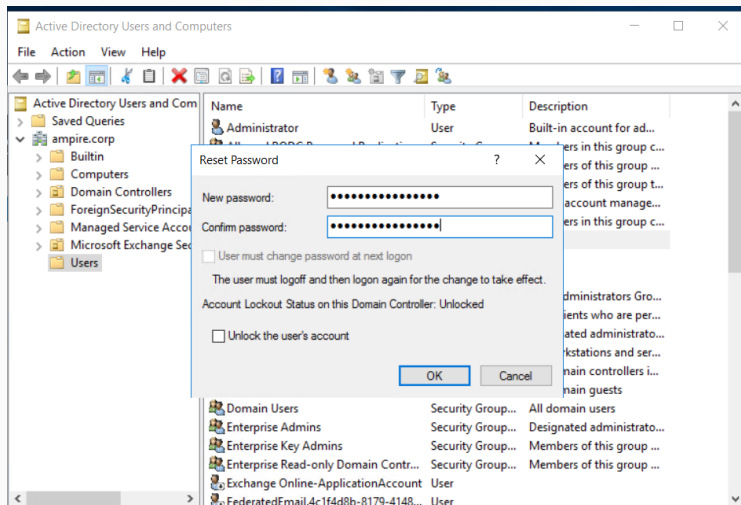


Рис. 3: Изменение пароля

Уязвимость 1. Слабый пароль пользователя.

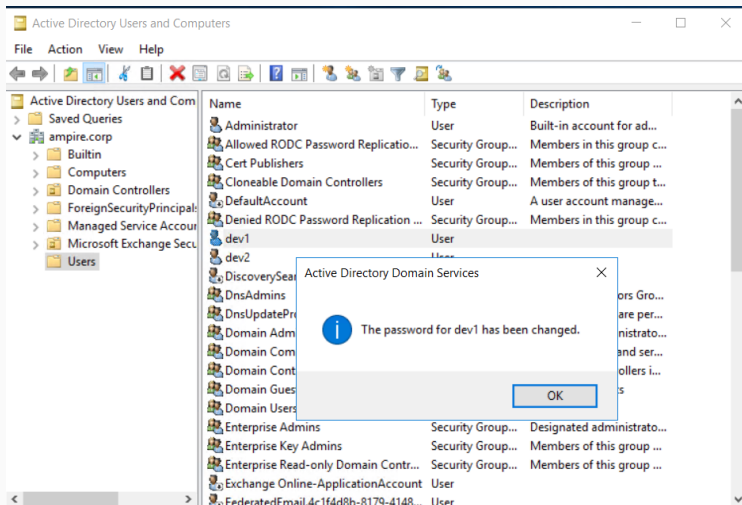


Рис. 4: Подтверждение изменения пароля пользователя dev1

Уязвимость 1. Слабый пароль пользователя.

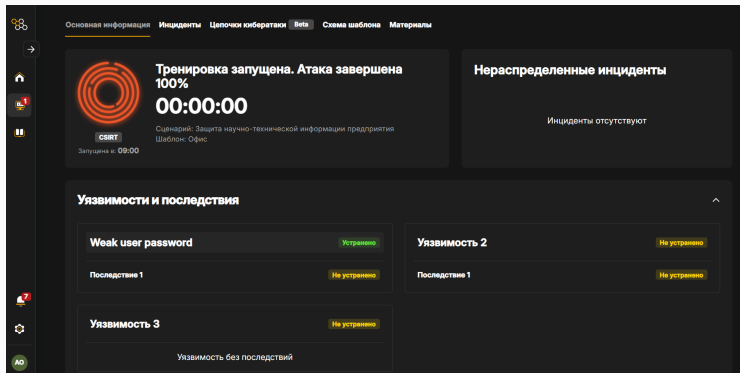


Рис. 5: Устранение уязвимости

Последствие уязвимости 1.

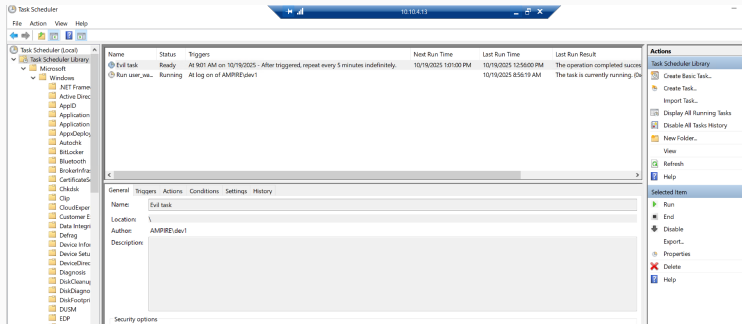


Рис. 6: Просмотр вредоносной задачи

Последствие уязвимости 1.

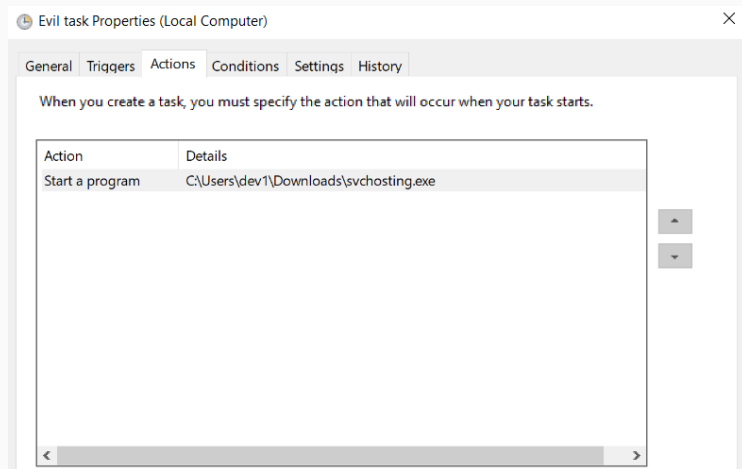


Рис. 7: Вредоносная задача

Последствие уязвимости 1.

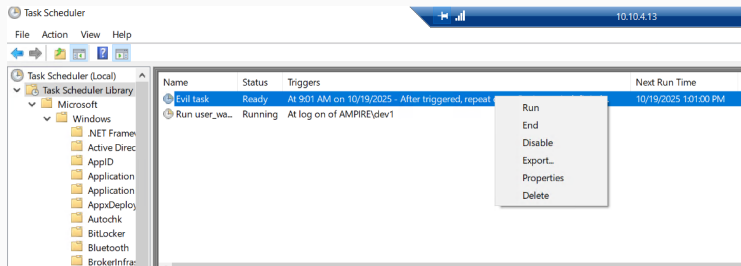


Рис. 8: Удаление задачи

Последствие уязвимости 1.

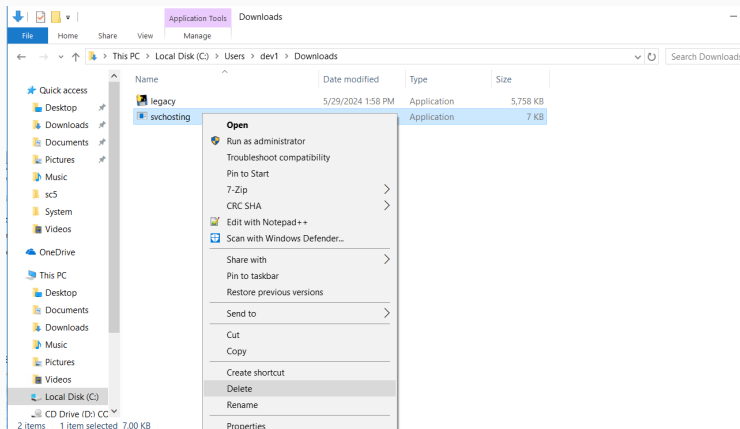


Рис. 9: Удаление вредоносного файла

Последствие уязвимости 1.

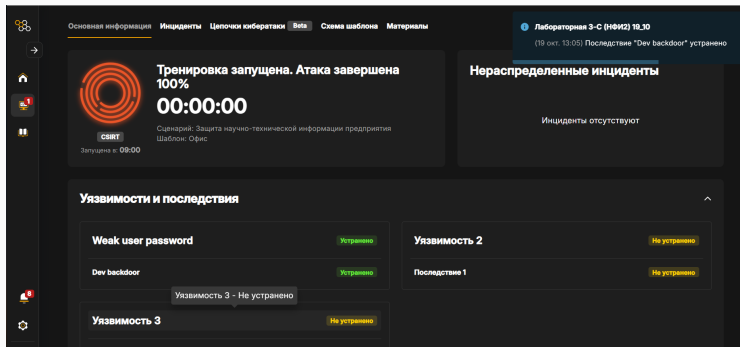


Рис. 10: Последствие устранено

Уязвимость 2. XSS (CVE-2019-17427).

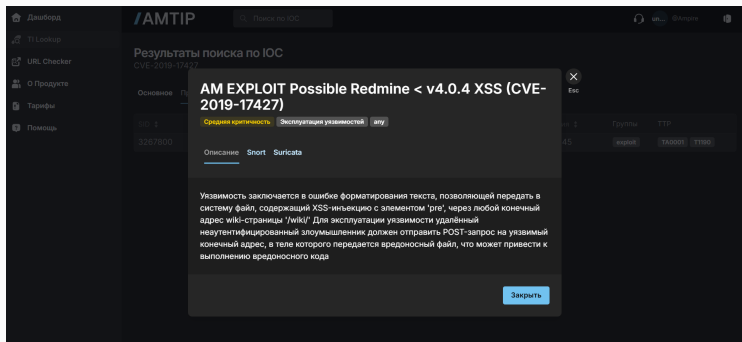


Рис. 11: Описание уязвимости

Уязвимость 2. XSS (CVE-2019-17427).

Атака XSS

Основная информация

Чат

В работе

Дата и время события

19.10.2025 13:14

Описание

Уязвимость заключается в ошибке форматирования текста, позволяющей передать в систему файл, содержащий XSS-инъекцию с элементом 'pre', через любой конечный адрес wiki-страницы '/wiki/'
Для эксплуатации уязвимости удаленный неаутентифицированный злоумышленник должен отправить POST-запрос на уязвимый конечный адрес, в теле которого передается вредоносный файл, что может привести к выполнению вредоносного кода.

Индикаторы компрометации

Ошибки форматирования

Рекомендации

Внести изменения в код Redmine

Оценка

☆☆☆☆☆

Автор

Абакумова Олеся
@1132220832@pfur.ru

Ответственный

Абакумова Олеся @1132220832@pfur.ru

Источник

10.10.4.11

Пораженные активы

10.10.2.15

Рис. 12: Добавление инцидента по уязвимости 2

15/33

Уязвимость 2. XSS (CVE-2019-17427).

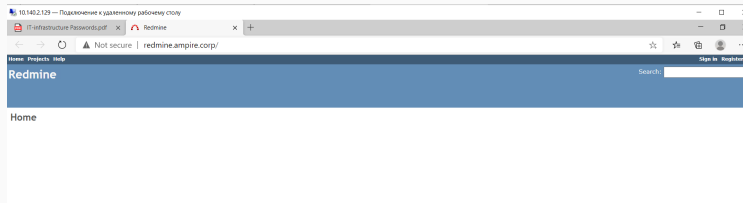


Рис. 13: Просмотр главной страницы сайта

Уязвимость 2. XSS (CVE-2019-17427).

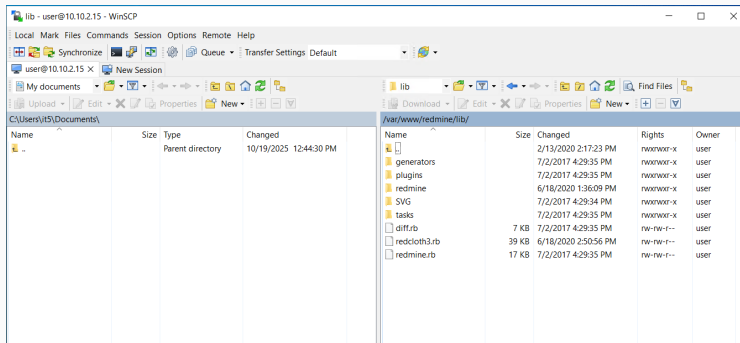
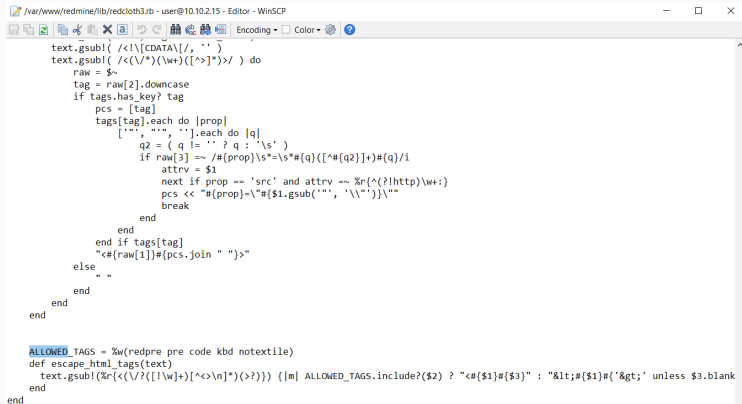


Рис. 14: Файл с уязвимостью

Уязвимость 2. XSS (CVE-2019-17427).

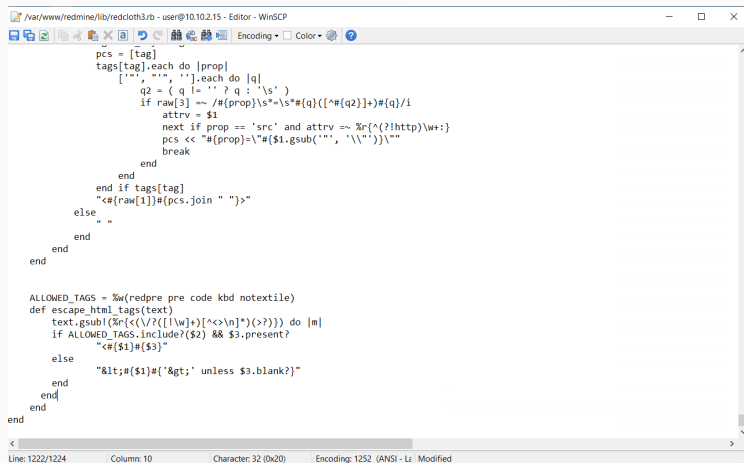


```
/var/www/redmine/lib/redcloth3.rb - user@10.10.2.15 - Editor - WinSCP
text.gsub!( /<![CDATA\[/, '' )
text.gsub!( /<(\/*)(\w+)([>]*)>/ ) do
  raw = $~
  tag = raw[2].downcase
  if tags.has_key? tag
    pcs = [tag]
    tags[tag].each do |prop|
      [ "'", '"', '`' ].each do |q|
        q2 = ( q != "'" ? q : '"' )
        if raw[3] =~ /#{prop}\s*=\s*#{q}([^\s#{q}]+)#{q}/i
          attrv = $1
          next if prop == 'src' and attrv =~ %r{^(?!http)\w+:}
          pcs << " #{prop}=\"#{ $1.gsub("'", '"') }\""
          break
        end
      end
    end if tags[tag]
    "<#{raw[1]}#{pcs.join " "}>"
  else
    ""
  end
end
end
end

ALLOWED_TAGS = %w(redpre pre code kbd notextile)
def escape_html_tags(text)
  text.gsub!(%r{<(\/*)([! \w+)](< > \n)*(>?)}) { |m| ALLOWED_TAGS.include?( $2 ) ? "<#{ $1 }#{ $3 }" : "&lt;#{ $1 }#{ $3 }" unless $3.blank? }
end
end
```

Рис. 15: Содержимое файла redcloth3.rb

Уязвимость 2. XSS (CVE-2019-17427).



```

/var/www/redmine/lib/redcloth3.rb - user@10.10.2.15 - Editor - WinSCP

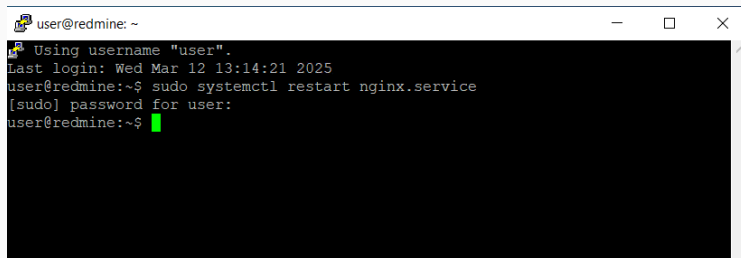
pcs = [tag]
tags[tag].each do |prop|
  [ "'", '"', '`' ].each do |q|
    q2 = ( q != "'" ? q : '\s' )
    if raw[3] =~ /#{prop}\s*=\s*#{q}([^\s#{q}]+)\s*#{q}/i
      attrv = $1
      next if prop == 'src' and attrv =~ %r{^(?!http)\w+:}
      pcs << "#{prop}=\"#{$.gsub("'", '"')}\""
      break
    end
  end
end if tags[tag]
"<#{raw[1]}#{pcs.join " "}>"
else
  ""
end
end
end

ALLOWED_TAGS = %w(redpre pre code kbd notextile)
def escape_html_tags(text)
  text.gsub!(/%r{<\/?([!\\w]+)[^<>\n]*(>?)}) do |m|
    if ALLOWED_TAGS.include?( $2 ) && $3.present?
      "<#{ $1 }#{ $3 }"
    else
      "&lt;#{ $1 }#{ $3 }" unless $3.blank?
    end
  end
end
end
end
```

Line: 1222/1224 Column: 10 Character: 32 (0x20) Encoding: 1252 (ANSI - Lz Modified)

Рис. 16: Внесем изменения в файл

Уязвимость 2. XSS (CVE-2019-17427).



```
user@redmine: ~  
Using username "user".  
Last login: Wed Mar 12 13:14:21 2025  
user@redmine:~$ sudo systemctl restart nginx.service  
[sudo] password for user:  
user@redmine:~$
```

Рис. 17: Перезапуск службы

Уязвимость 2. XSS (CVE-2019-17427).

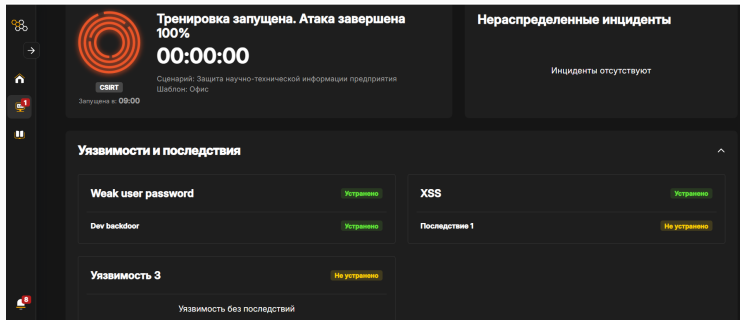


Рис. 18: Уязвимость 2 устранена

Последствие уязвимости 2.

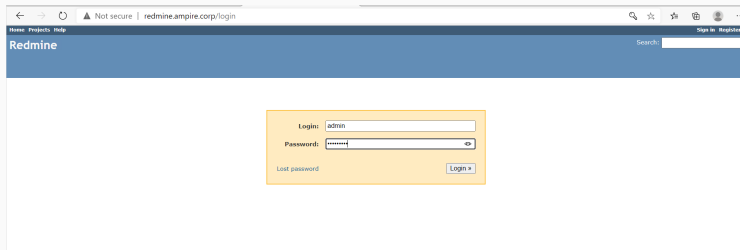


Рис. 19: Вход в консоль администратора

Последствие уязвимости 2.

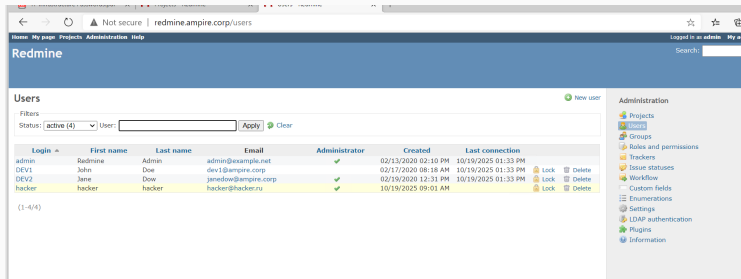


Рис. 20: Список пользователей Redmine

Последствие уязвимости 2.

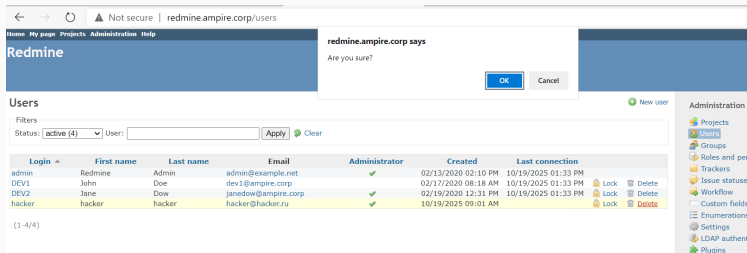


Рис. 21: Удаление пользователя hacker

Последствие уязвимости 2.

← → ↻ ⚠ Not secure | redmine.ampire.corp/users

Home My page Projects Administration Help

Redmine

Users ➕ New user

Filters

Status: **active (3)** User:

Login	First name	Last name	Email	Administrator	Created	Last connection
admin	Redmine	Admin	admin@example.net	✓	02/13/2020 02:10 PM	10/19/2025 01:33 PM
DEV1	John	Doe	dev1@ampire.corp		02/17/2020 08:18 AM	10/19/2025 01:34 PM Lock Delete
DEV2	Jane	Dow	janedow@ampire.corp	✓	02/19/2020 12:31 PM	10/19/2025 01:33 PM Lock Delete

(1-3/3)

Рис. 22: Пользователь hacker ликвидирован

Последствие уязвимости 2.

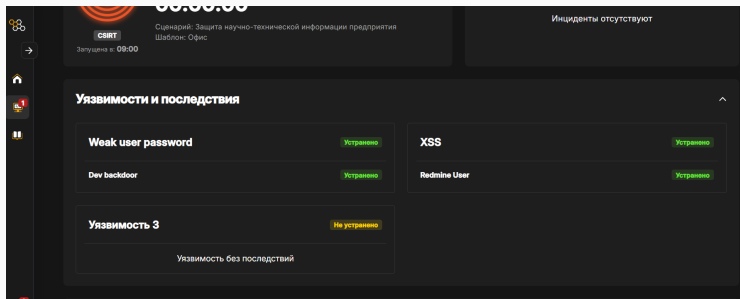


Рис. 23: Последствие уязвимости 2 устранено

Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.

The screenshot displays the AMTIP web application interface. On the left is a dark sidebar with navigation links: Дашборд, TI Lookup, URL Checker, О Продукте, Тарифы, and Помощь. The main content area has a header with the AMTIP logo and a search bar. Below the header, the page title is 'Результаты поиска по IOC' with 'CVE-2019-18890' underneath. There are four tabs: Основное (selected), Правила обнаружения вторжений, Взаимосвязи, and Граф. The 'Обзор CVE-2019-18890' section contains a table with details about the vulnerability. Below this is a section for 'Покрывтие уязвимости в продуктах ViPNet' and a 'Загрузки' section with a 'Смотреть загрузки' button.

Название уязвимости:	Уязвимость Blind SQL
Описание уязвимости:	В Redmine до версии 3.2.9 и 3.3.x до версии 3.3.10 уязвимость позволяет пользователям Redmine получать доступ к защищенной информации с помощью сгенерированного объектного запроса.
Рекомендации по нейтрализации:	- Внести изменения в код Redmine

Рис. 24: Информация о CVE-2019-18890

Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.

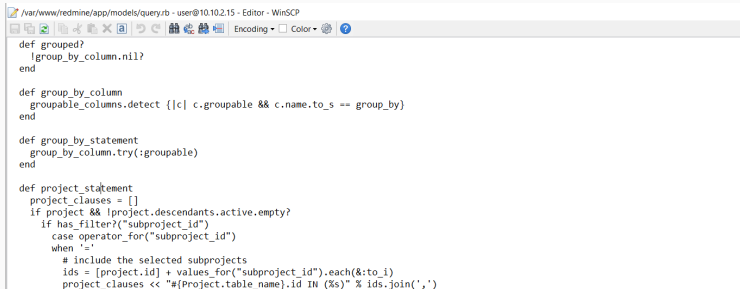
The screenshot shows a web interface for a security laboratory. The main window displays an incident card for 'Blind SQL-инъекция' (Blind SQL injection). The card includes the following fields:

- Название:** Blind SQL-инъекция
- Дата и время события:** 19.10.2025 13:42
- Источник:** 10.10.4.11 (Manager Workstation 1)
- Пораженные активы:** 10.10.2.15 (Redmine Server)
- Описание:** В Redmine до версии 3.2.9 и 3.3.x до версии 3.3.10 уязвимость позволяет пользователям Redmine получать доступ к защищенной информации с помощью сгенерированного объектного запроса.
- Рекомендации:** Внести изменения в код Redmine
- Индикаторы компрометации:** Время прихода пакета является индикатором: при
- Прикрепить файл:** A section with a dashed border and a prompt 'Перетяните файл в эту область или Выберите файл'.

At the bottom right of the card are two buttons: 'Отмена' (Cancel) and 'Добавить' (Add). The background interface shows a sidebar with navigation options like 'Основная информация', 'Поиск', 'Закрывать', 'Слабый пароль', 'Автор', and 'Сообщения'.

Рис. 25: Карточка инцидента для уязвимости 3

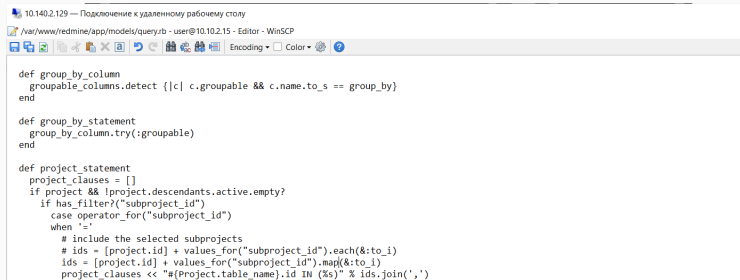
Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.



```
def grouped?  
  !group_by_column.nil?  
end  
  
def group_by_column  
  groupable_columns.detect {|c| c.groupable && c.name.to_s == group_by}  
end  
  
def group_by_statement  
  group_by_column.try(:groupable)  
end  
  
def project_statement  
  project_clauses = []  
  if project && !project.descendants.active.empty?  
    if has_filter?("subproject_id")  
      case operator_for("subproject_id")  
      when '='  
        # include the selected subprojects  
        ids = [project.id] + values_for("subproject_id").each(&:to_i)  
        project_clauses << "#{Project.table_name}.id IN (#{ids.join(',')})"  
      end  
    end  
  end  
end
```

Рис. 26: Файл query.rb

Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.



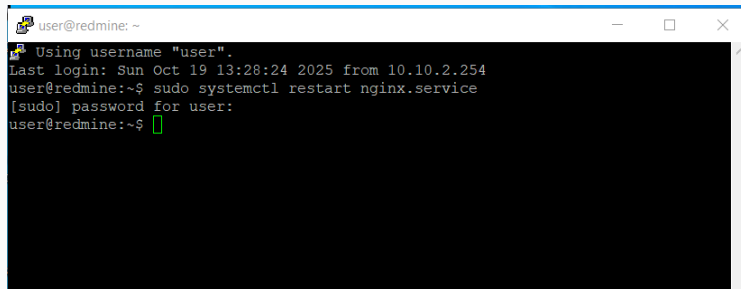
```
def group_by_column
  groupable_columns.detect {|c| c.groupable && c.name.to_s == group_by}
end

def group_by_statement
  group_by_column.try(:groupable)
end

def project_statement
  project_clauses = []
  if project && !project.descendants.active.empty?
    if has_filter?("subproject_id")
      case operator_for("subproject_id")
      when '='
        # include the selected subprojects
        # ids = [project.id] + values_for("subproject_id").each(&:to_i)
        ids = [project.id] + values_for("subproject_id").map(&:to_i)
        project_clauses << "#{Project.table_name}.id IN (%s)" % ids.join(',')
      end
    end
  end
end
```

Рис. 27: Внесение изменений в файл query.rb

Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.



```
user@redmine: ~  
Using username "user".  
Last login: Sun Oct 19 13:28:24 2025 from 10.10.2.254  
user@redmine:~$ sudo systemctl restart nginx.service  
[sudo] password for user:  
user@redmine:~$
```

Рис. 28: Перезапуск службы веб-сервера

Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.

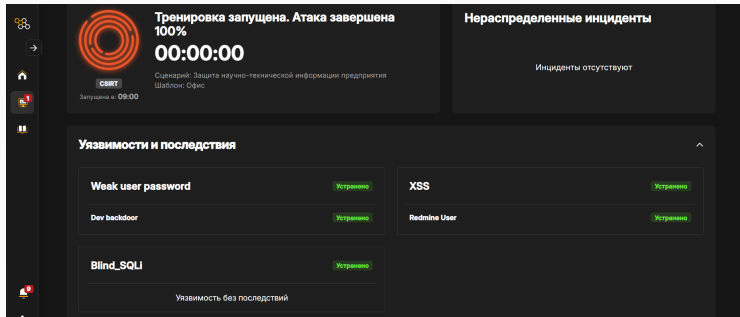


Рис. 29: Все уязвимости и последствия устранены

Мы защитили научно-техническую информацию предприятия от внутреннего нарушителя и устранили последствия его атак.